Operationalizing CVSS v4.0 Environmental Metrics with Evidence Normalization, Governance, and Traceability

Anonymous Author(s)
Affiliation withheld for double-blind review

***Abstract*—CVSS v4.0 provides Environmental metrics for adapting vulnerability assessment to the deployment context of a consumer organization, but selecting those metrics remains evidence-intensive. This paper presents an evidence normalization, governance, and traceability workflow that collects, structures, and traces environmental evidence while preserving official CVSS semantics and human responsibility for final metric selection. The workflow separates Base vulnerability information from consumer-side context, resolves candidate Environmental values under explicit governance policies, records uncertainty, enforces human authorization requirements, and exports reproducible artifacts. The evaluation strictly separates specification-level arithmetic conformance validation from controlled workflow evaluation across curated scenarios. At the specification level, the scoring core demonstrated 100.00% conformance across 486,472 official FIRST reference corpus vectors (commit `d766d0c8ab4368b67bf27dd0e411eb481f05fdbb`) and zero invariant violations across 10,000 metamorphic executions. Under controlled scenario evaluation with a hybrid dataset of 30 scenarios (12 real NVD records carrying CVSS v4.0 data and 18 curated synthetic cases), the workflow achieved 100.00% evidence coverage, 100.00% trace completeness, and operational priority changes in 22 of 30 scenarios. The evaluation demonstrates workflow schema completeness, context sensitivity, and traceability under construction-controlled conditions; it does not establish autonomous scoring accuracy, predictive superiority, or production effectiveness.**

***Index Terms*—CVSS v4.0, Environmental metrics, vulnerability prioritization, evidence normalization, governance, human-in-the-loop, traceability, reproducibility, uncertainty**

I. Introduction

Vulnerability management teams routinely face more findings than they can remediate immediately. A severity score is therefore an important input, but it does not by itself encode every factor that affects an organization's remediation decision. The same vulnerability may affect an isolated development workstation, a public identity service, a safety-relevant operational technology component, or a redundant internal service. These deployments can require different treatment even when the vulnerability's intrinsic technical characteristics are unchanged.

CVSS v4.0 explicitly separates Base, Threat, Environmental, and Supplemental metric groups [1], [2]. Base metrics communicate characteristics intrinsic to the vulnerability, whereas Environmental metrics allow a consumer organization to represent local security requirements and modified conditions [3], [4]. This separation creates an opportunity for context-aware assessment, but also an operational burden: analysts must locate evidence, interpret incomplete information, document assumptions, and preserve the reasoning behind each metric choice.

This paper investigates whether an evidence normalization and governance workflow can assist that process without modifying CVSS or displacing human judgment. Assistive watcher components are defined as evidence-processing tools rather than autonomous scoring authorities. The pipeline ingests candidate evidence, normalizes it into a structured scenario record, resolves reviewable candidate metric values under deterministic policy rules, identifies uncertainty, and exports trace artifacts. A human analyst remains responsible for accepting, changing, or rejecting each recommendation.

The work makes five contributions:

1) a strict scientific separation between specification-level arithmetic conformance (486,472 FIRST reference cases; 10,000 metamorphic executions with zero violations) and controlled workflow evaluation across curated scenarios;
2) an evidence normalization and human-in-the-loop governance workflow for operationalizing CVSS v4.0 Environmental assessment;
3) a trace model linking evidence, candidate metrics, uncertainty, and review state;
4) a controlled evaluation dataset of curated scenarios exercising schema coverage (12 real NVD records, 18 synthetic cases, 22 priority shifts); and
5) a reproducible artifact package with validators, tables, JSON traces, manuscript sources, and compilation outputs.

The evaluation is deliberately descriptive. It measures artifact completeness, traceability, and context-sensitive operational transitions. It does not claim that the watcher predicts exploitation, produces an authoritative risk score, or improves remediation outcomes in production.

II. Background and Related Work

A. Severity and Environmental Context

CVSS is an open framework for communicating vulnerability characteristics and severity. CVSS v4.0 retains a Base metric group while distinguishing Threat, Environmental, and Supplemental information [2], [3]. Environmental assessment includes Security Requirements and Modified Base metrics, allowing the consumer to represent conditions that differ from the vulnerable system's default assumptions.

The need for contextualization predates CVSS v4.0. Fruhwirth and Mannisto examined the use of context information to improve CVSS-based prioritization and response [5]. Later context-aware approaches, including CAVP, combined vulnerability attributes with additional operational signals to support prioritization [6]. These approaches motivate automation, but they also show that context must be represented explicitly rather than inferred solely from a Base score.

Howland argues that CVSS has often been used outside its intended role, particularly when technical severity is treated as a complete vulnerability management decision [7]. The present work addresses that concern by retaining Base severity as a separate field and labeling the prototype's priority output as an operational category rather than an official CVSS score.

B. CVSS v4.0 Nomenclature and Scoring Mechanics

The official FIRST specification establishes four formal nomenclature tiers depending on the metric groups populated in a score vector:

- **CVSS-B:** Base metrics only, quantifying intrinsic vulnerability characteristics across Exploitability (AV, AC, AT, PR, UI), Vulnerable System Impact (VC, VI, VA), and Subsequent System Impact (SC, SI, SA).
- **CVSS-BT:** Base and Threat metrics, incorporating Exploit Maturity ($E \in \{\text{Attacked}, \text{Proof-of-Concept}, \text{Unreported}, \text{Not Defined}\}$).
- **CVSS-BE:** Base and Environmental metrics, incorporating consumer-specific context without threat intelligence.
- **CVSS-BTE:** Base, Threat, and Environmental metrics combined, reflecting contemporary exploit activity alongside consumer deployment context.

Environmental assessment in CVSS v4.0 operates across two distinct mechanisms:

1) **Modified Base Metrics:** Allow the consumer organization to override intrinsic Base values when local defenses, privilege architectures, or compensating controls alter attack difficulty or impact. These comprise Modified Attack Vector (MAV), Modified Attack Complexity (MAC), Modified Attack Requirements (MAT), Modified Privileges Required (MPR), Modified User Interaction (MUI), Modified Vulnerable System Impacts (MVC, MVI, MVA), and Modified Subsequent System Impacts (MSC, MSI, MSA). When unmodified, each metric defaults to its underlying Base value ($MX = X$).
2) **Security Requirements:** Express consumer-side mission criticality for Confidentiality Requirement (CR), Integrity Requirement (IR), and Availability Requirement (AR), taking values in $\{\text{High}, \text{Medium}, \text{Low}, \text{Not Defined}\}$. CR, IR, and AR rescale effective impact weights during MacroVector evaluation.

Under the FIRST CVSS v4.0 standard, scoring does not follow an informal arithmetic formula. Vectors are mapped into a 6-dimensional discrete MacroVector:

$$\vec{M} = (EQ_1, EQ_2, EQ_3, EQ_4, EQ_5, EQ_6) \tag{1}$$

where EQ_1 captures Exploitability (AV/PR/UI), EQ_2 captures Complexity (AC/AT), EQ_3 captures Vulnerable System Impact scaled by CR/IR/AR, EQ_4 captures Subsequent System Impact, EQ_5 captures Threat (E), and EQ_6 captures Modified Subsequent System Impact. Each MacroVector corresponds to a precomputed Equivalence Set with assigned boundary scores. The final score is resolved through deterministic interpolation between adjacent equivalence boundaries.

Crucially, the workflow presented in this paper does not reimplement or approximate this algorithm. Instead, the workflow ingests local evidence, resolves applicable policy rules into valid Modified metrics and Security Requirements, and delegates calculation to the canonical FIRST-compatible scoring core (independently validated against 486,472 official reference vectors).

C. Stakeholder-Specific Prioritization

The Stakeholder-Specific Vulnerability Categorization framework models prioritization as a decision process that depends on the stakeholder and its objectives [8]. SSVC uses decision trees and explicitly rejects a single universal ordering for every vulnerability management community. This perspective is compatible with CVSS Environmental assessment: both require consumer-specific information that cannot be obtained from the vulnerability record alone.

The workflow proposed here does not implement an SSVC decision tree. Instead, it adopts two related principles. First, the evidence record must identify the consumer context. Second, the decision artifact must remain inspectable so that an analyst can understand which local facts changed the recommendation.

D. Threat and Exploit Prediction

EPSS addresses a different question from CVSS severity. It estimates the probability that exploitation activity will be observed for a vulnerability within a future time window. Research underlying EPSS demonstrates the value of data-driven exploit prediction for allocating remediation effort [9], [10], [11].

Threat probability and Environmental impact are complementary rather than interchangeable. An exploit prediction model can inform the urgency associated with attacker activity, while Environmental metrics express consumer-side requirements and modified deployment conditions. The proposed watcher keeps those concepts separate and treats time-sensitive threat evidence as an input requiring freshness checks.

E. Enterprise Patch and Risk Decisions

NIST SP 800-40 Rev. 4 frames enterprise patch management as a lifecycle that includes identification, prioritization, acquisition, installation, and verification [12]. The guidance also emphasizes coordination between mission owners and technology management. This reinforces the need for artifacts that communicate why a vulnerability was prioritized, not merely the numeric value attached to it.

Recent empirical comparison of CVSS, SSVC, EPSS, and other scoring systems shows that different systems can rank

the same vulnerabilities differently because they have different purposes and underlying signals [13]. The implication for this work is not that one system must replace the others. Instead, a defensible workflow should expose the signal being used, the decision boundary, and the evidence supporting the result.

F. Research Gap

Prior work establishes the value of contextual information, stakeholder decisions, exploit prediction, and enterprise prioritization. A remaining operational gap is the reproducible transformation of distributed local evidence into candidate CVSS v4.0 Environmental values. The contribution of this work is therefore the traceable workflow around Environmental assessment: evidence acquisition, normalization, recommendation, uncertainty signaling, human review, and reproducible export.

III. Research Questions and Design Goals

The evaluation addresses three research questions.

- RQ1: Can the workflow produce complete evidence and trace artifacts for each evaluated scenario?
- RQ2: Does consumer-side context produce observable changes in an operational priority view relative to a Base-only view?
- RQ3: Can uncertainty and human-review requirements be represented explicitly enough to prevent watcher output from being presented as an autonomous official score?

Table I maps each research question to its descriptive measure and interpretation boundary.

The design goals derived from these questions are separation of concerns, provenance, conservative uncertainty handling, deterministic exports, idempotent validation, and explicit human authority.

IV. Evidence Normalization Architecture

Figure 1 summarizes the architecture. The workflow is organized into six logical layers.

A. Source Adapters

Source adapters ingest vulnerability records and consumer-side evidence. Vulnerability identifiers, Base vectors, Base scores, severity labels, source URLs, and retrieval metadata remain distinct from local asset observations. This separation prevents curated deployment context from being represented as if it originated in NVD.

Consumer-side inputs may include asset role, exposure, privileges, security controls, redundancy, confidentiality needs, integrity needs, availability needs, and operational constraints. The prototype stores concise evidence summaries rather than claiming direct integration with a production CMDB, scanner, ticketing platform, or threat-intelligence system.

B. Evidence Normalization

The normalization layer converts heterogeneous observations into a stable scenario schema. Each record contains identifiers, official Base information, environmental context, candidate modified metrics, evidence summaries, uncertainty flags, review state, and trace references. Required-field validators detect omissions before article tables or reports are generated.

Normalization is important because an automated recommendation without a stable evidence model is difficult to review or reproduce. The architecture must therefore produce structured fields in addition to narrative text.

C. Candidate Recommendation Layer

The recommendation layer maps the normalized context to candidate Environmental values. The candidate status is essential: the output is not declared to be an authoritative score. The rationale field explains which evidence supports each recommendation, while uncertainty fields identify assumptions, stale observations, missing data, or conflicts.

The evaluated prototype focuses on deterministic evidence normalization, governance gates, and trace generation rather than the semantic accuracy of an unconstrained generative AI model. Any assistive language processing or watcher heuristics are strictly scoped to evidence ingestion support and remain outside the scope of semantic truth validation; candidate values are resolved through structured scenario logic, deterministic policy rules, and curated evidence schemas. No claim is made that an artificial intelligence model independently discovered or empirically validated ground-truth metric values.

D. Human Authorization Checkpoint

Every scenario requires review. The reviewer can accept, modify, reject, or defer a recommendation. The workflow's governance model requires the final record to retain the original candidate, the reviewer state, and the evidence available at assessment time.

This checkpoint limits automation bias by making uncertainty and provenance visible. It also supports later comparison between watcher recommendations and expert assessments, which is planned as future work.

E. Trace and Export Layer

Each scenario produces a trace artifact containing source metadata, evidence, candidate decisions, uncertainty, and review state. Dataset-level scripts generate CSV, JSON, Markdown, LaTeX, validation metrics, and summary tables. The exported artifacts provide a reproducible snapshot of the workflow state.

V. Dataset and Experimental Method

A. Validation Structure and Separation

The evaluation is structured into two strictly separated tiers: specification-level conformance verification and controlled workflow evaluation. Specification-level verification evaluates whether the scoring engine adheres to the CVSS v4.0 mathematical standard and maintains formal monotonicity properties. Controlled workflow evaluation assesses whether the evidence

TABLE I
RESEARCH QUESTIONS, MEASURES, AND INTERPRETATION BOUNDARIES

RQ	Question focus	Measures	Boundary
RQ1	Artifact completeness and reproducibility	Evidence coverage; trace completeness; validator status	Completeness does not prove metric correctness.
RQ2	Sensitivity to curated consumer context	Priority transition count; transition distribution; category delta	The category delta is not an official CVSS score delta.
RQ3	Reviewability and uncertainty governance	Uncertainty fields; review-required state; claim-boundary checks	Review state does not constitute independent expert adjudication.

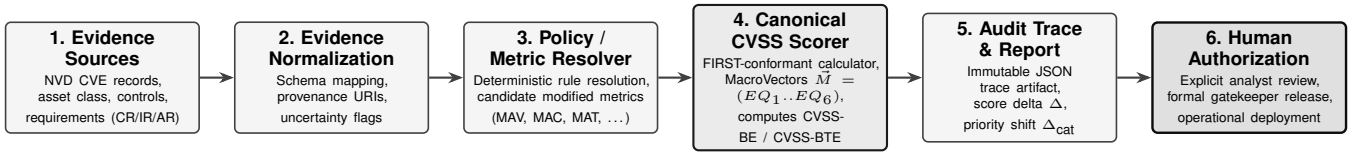


Fig. 1. End-to-end architecture of the CVSS v4.0 environmental assessment workflow, emphasizing evidence normalization, deterministic policy resolution, canonical scoring conformance, audit traceability, and explicit human authorization.

normalization pipeline successfully structures evidence, flags uncertainty, enforces human authorization requirements as a governance constraint, and exports reproducible artifacts across curated scenarios.

B. Specification-Level Verification Design

To establish a mathematically verified baseline prior to evaluating the operational workflow, the deterministic scoring core was evaluated against the official FIRST reference corpus Round 5, comprising 486,472 vectors evaluated against pinned FIRST commit `d766d0c8ab4368b67bf27dd0e411eb481f05fdbb`. In addition, a metamorphic testing campaign evaluated 10,000 executions across four metamorphic relations: MR-1 (monotonicity of criticality), MR-2 (defense removal monotonicity), MR-3 (context permutation invariance), and MR-4 (irrelevant control invariance). Specification-level verification establishes arithmetic conformance to published standards; it does not evaluate contextual suitability or operational effectiveness in production.

C. Formal Specification of Metamorphic Relations

Let $\mathcal{V}$ denote the space of valid CVSS v4.0 Base vectors, $\mathcal{E}$ the space of structured environmental evidence contexts, and $f : \mathcal{V} \times \mathcal{E} \to \mathbb{R} \times \mathcal{M}$ the deterministic evaluation pipeline returning an Environmental score $S(v, e) \in [0.0, 10.0]$ and candidate modified metrics $M(v, e) \in \mathcal{M}$. The campaign (Campaign ID: `HELPUS-METAMORPHIC-10K-G9B`) evaluated 10,000 executions ($2,500$ per relation) across four formal relations:

1) **MR-1 (Monotonicity of Criticality):** Let $e \in \mathcal{E}$ have security requirements $R \in \{\text{CR}, \text{IR}, \text{AR}\}$ ordered as L $<$ M $<$ H. Let $T_{\text{MR1}}(e)$ elevate one or more requirements to $R' > R$ ceteris paribus.

$$S(v, T_{\text{MR1}}(e)) \geq S(v, e) \tag{2}$$

Violation criterion: $S(v, T_{\text{MR1}}(e)) < S(v, e)$.

2) **MR-2 (Defense Removal Monotonicity):** Let $e_{\text{def}} \in \mathcal{E}$ specify reachability under active defense or isolation (reachability $\in \{\text{ADJACENT_ONLY}, \text{LOCAL_ONLY}, \text{PHYSICAL_ONLY}\}$). Let $T_{\text{MR2}}(e_{\text{def}}) = e_{\text{unprot}}$ remove network defenses (reachability = PUBLIC_ROUTED, internet_exposed = True).

$$S(v, T_{\text{MR2}}(e_{\text{def}})) \geq S(v, e_{\text{def}}) \tag{3}$$

Violation criterion: $S(v, T_{\text{MR2}}(e_{\text{def}})) < S(v, e_{\text{def}})$.

3) **MR-3 (Context Permutation Invariance):** Let $e = \{(k_i, v_i)\}_{i=1}^{n}$ be an evidence set, and let $\pi \in \Pi_n$ be an arbitrary key-ordering permutation.

$$S(v, \pi(e)) = S(v, e) \quad \wedge \quad M(v, \pi(e)) = M(v, e) \tag{4}$$

Violation criterion: $S(v, \pi(e)) \neq S(v, e) \vee M(v, \pi(e)) \neq M(v, e)$.

4) **MR-4 (Irrelevant Control Invariance):** Let I be an evidence subset disjoint from CVSS environmental evaluation parameters ($I \cap \text{dom}(\mathcal{E}) = \emptyset$, e.g., backup logs, unrelated software flags).

$$S(v, e \cup I) = S(v, e) \quad \wedge \quad M(v, e \cup I) = M(v, e) \tag{5}$$

Violation criterion: $S(v, e \cup I) \neq S(v, e) \vee M(v, e \cup I) \neq M(v, e)$.

These relations characterize verified invariants within the finite campaign ($2,500$ executions per relation, zero violations); they do not constitute an exhaustive universal mathematical proof across infinite input spaces.

D. Unit of Analysis

The unit of analysis is an environmental assessment scenario. A scenario combines a vulnerability severity baseline with a consumer deployment context and a candidate Environmental assessment. Scenarios are evaluated as workflow records rather than independent observations of production risk.

E. Hybrid Dataset

The dataset contains 30 scenarios. 12 scenarios use real NVD records carrying CVSS v4.0 Base information [14], [15], [16], [17], [18], [19], [20], [21], [22], [23], [24], [25]. The remaining 18 scenarios are curated synthetic cases designed to exercise contextual differences.

The hybrid design provides two kinds of control. Real NVD records preserve authentic vulnerability identifiers, Base vectors, and source metadata. Synthetic cases allow deliberate variation of context without implying that the scenario corresponds to an observed production deployment.

The Environmental context associated with the NVD rows is curated locally. NVD supplies vulnerability information, not the consumer organization's asset criticality, compensating controls, or mission requirements. The manuscript and dataset label this boundary explicitly.

F. Scenario Construction

Scenario construction follows four steps. First, the pipeline selects or creates a Base vulnerability record. Second, it assigns a consumer context template describing asset role, exposure, and security requirements. Third, it generates candidate modified metrics and a rationale. Fourth, it exports an uncertainty flag and review-required state.

The synthetic scenarios are not intended to simulate the statistical distribution of enterprise assets. They are controlled test cases for the workflow schema and validators. Similarly, the NVD sample is time-bounded and is not claimed to represent the population of CVSS v4.0 vulnerabilities.

G. Measures

Evidence coverage is the percentage of scenarios containing the required evidence representation. Trace completeness is the percentage containing the required per-scenario trace structure. Review coverage reports the presence of a human-review state. Uncertainty coverage reports whether uncertainty is represented explicitly.

Context sensitivity is measured by comparing the Base-only operational priority P_{base} with the Environmental-aware operational priority P_{env}. Priorities belong to the ordered set:

$$\mathcal{P} = \langle \text{defer}, \text{low}, \text{medium}, \text{high}, \text{critical} \rangle \tag{6}$$

with the bijective ordinal mapping $g : \mathcal{P} \to \{0, 1, 2, 3, 4\}$ defined as:

$$g(p) = \begin{cases} 0, & p = \text{defer} \\ 1, & p = \text{low} \\ 2, & p = \text{medium} \\ 3, & p = \text{high} \\ 4, & p = \text{critical} \end{cases} \tag{7}$$

The base priority $P_{\text{base}} \in \{\text{defer}, \text{low}, \text{medium}, \text{high}, \text{critical}\}$ is mapped from the official qualitative severity of the Base score S_{base} via $P_{\text{base}} = \text{severity}(S_{\text{base}})$. Consumer-side operational prioritization derives the contextual priority P_{env} via a deterministic policy function $h(P_{\text{base}}, e)$ defined over the deployment context e:

$$g(P_{\text{env}}) = \min(4, \max(0, g(P_{\text{base}}) + w_{\text{context}}(e) + w_{\text{control}}(e))) \tag{8}$$

where $w_{\text{context}}(e) \in \{0, 1, 2\}$ reflects deployment exposure ($+2$ for public web services, 0 for restricted administrative segments) and $w_{\text{control}}(e) \in \{-1, 0\}$ reflects active compensating controls (-1 for defense-in-depth, network segmentation, or multi-factor authentication).

The Category Delta Δ_{cat} for a scenario is formally defined as:

$$\Delta_{\text{cat}} = g(P_{\text{env}}) - g(P_{\text{base}}) \tag{9}$$

where $\Delta_{\text{cat}} > 0$ denotes priority escalation (up to $+2.0$), $\Delta_{\text{cat}} < 0$ denotes priority de-escalation (down to -3.0), and $\Delta_{\text{cat}} = 0$ denotes unchanged priority. Across the $N = 30$ curated scenarios, the sample mean category delta is:

$$\bar{\Delta}_{\text{cat}} = \frac{1}{N} \sum_{i=1}^{N} \Delta_{\text{cat}}^{(i)} = \frac{6.0}{30} = 0.2 \tag{10}$$

confirming the exact empirical summary reported in the dataset metrics. The priority categories are prototype workflow labels, and their numeric difference is a custom category delta rather than an official CVSS specification metric. This formal separation explains why in Table V several CVEs exhibit a numeric score delta of 0.0 while undergoing an operational priority shift ($\Delta_{\text{cat}} = \pm 1$): S_{env} is governed strictly by the official FIRST MacroVector equivalence classes, whereas P_{env} incorporates consumer-side deployment exposure and compensating control policy weights outside the CVSS scoring engine.

TABLE II
DATASET AND WORKFLOW SUMMARY

Measure	Value
Scenarios	30
NVD/CVSS v4.0 records	12
Curated synthetic scenarios	18
Evidence coverage	100.00%
Trace completeness	100.00%
Explicit uncertainty fields	30/30
Operational priority shifts	22/30 (73.33%)

H. Validation Procedure

Validation is automated at multiple levels. Schema checks verify required fields and permitted source labels. Documentation checks verify claim boundaries. Result validators compare generated summaries with dataset-level metrics. LaTeX validation checks required sections, double-blind controls, bibliography keys, and forbidden claims. The PDF build uses `pdflatex`, `bibtex`, and repeated `pdflatex` passes to resolve citations.

VI. Results

A. Specification Conformance and Metamorphic Results

Specification-level evaluation demonstrated 100.00% arithmetic conformance with the official standard: 486,472 of 486,472 vectors in the FIRST reference corpus Round 5 passed with zero arithmetic divergences against pinned commit `d766d0c8ab4368b67bf27dd0e411eb481f05fdbb`. In the metamorphic testing campaign, 10,000 executions completed with zero invariant violations across all four relations (MR-1: 2,500/2,500; MR-2: 2,500/2,500; MR-3: 2,500/2,500; MR-4: 2,500/2,500; campaign ID `HELPUS-METAMORPHIC-10K-G9B`, verdict: PASSED). These results confirm that the underlying scoring core behaves as a deterministic, monotonic, and specification-conformant calculator, providing a verified foundation for empirical workflow evaluation.

B. Empirical Artifact Completeness and Traceability

All 30 scenarios contain evidence summaries and trace artifacts. Evidence coverage was 100.00 percent and trace completeness was 100.00 percent. All scenarios include an explicit review requirement, and uncertainty is represented in the scenario records.

These findings answer RQ1 at the workflow level: the prototype can generate the required artifacts consistently for the evaluated dataset. They do not establish that every candidate metric is semantically correct.

C. Context-Sensitive Priority Transitions

Operational priority changed in 22 of 30 scenarios (73.33 percent), while 8 scenarios retained the same category. The average category delta was 0.2. The observed range was -3.0 to 2.0.

Table III shows the transition distribution. Both upward and downward transitions are meaningful in the workflow. An upward transition can represent high local security requirements or more adverse deployment conditions. A downward transition can represent isolation, reduced requirements, or effective compensating conditions. Neither transition changes the official Base record.

The result supports RQ2 by showing that explicit consumer context can alter the prototype's operational ordering. Because contexts were curated, the result is a demonstration of sensitivity rather than evidence of real-world outcome improvement.

D. Severity Distribution

Table IV reports the Base severity distribution. This distribution is retained separately from operational transitions so that a reader can distinguish vulnerability severity from consumer prioritization.

E. Controlled Workflow Evaluation on Real NVD CVEs

The controlled workflow evaluation incorporates 12 real CVE records from the National Vulnerability Database (NVD) published with official CVSS v4.0 metrics, paired with curated organizational deployment contexts. Table V details the 12 cases, reporting the official input score and nomenclature (CVSS-B or CVSS-BT), contextual score and nomenclature (CVSS-BE or CVSS-BTE), numeric score delta, and operational priority shift (Δ_{cat}). This curated benchmark demonstrates operational workflow sensitivity under realistic vulnerability data rather than an independent sample of operational efficacy. Full 30-metric Base and Environmental vectors for all 12 cases are preserved in the reproducibility trace repository (`validation/article/trace/SCN-NVD-001.json` through `SCN-NVD-012.json`) and `data/article/cvss40_environmental_scenarios.csv`.

TABLE III
Operational Priority Transitions

Base priority	Environmental-aware priority	Count
critical	critical	3
high	critical	4
high	defer	1
high	high	2
high	medium	2
low	defer	2
low	high	1
low	low	1
low	medium	1
medium	critical	2
medium	defer	1
medium	high	6
medium	low	2
medium	medium	2

TABLE IV
CVSS-B Severity Distribution

Severity	Count
CRITICAL	3
HIGH	9
LOW	5
MEDIUM	13

F. Reviewability

The workflow preserves evidence, uncertainty, and review state instead of exporting only a final category. This supports RQ3 because an analyst can inspect the recommendation and its assumptions. However, the current review field indicates that review is required; it does not represent completed independent adjudication by multiple experts.

VII. Discussion

A. Completeness Versus Correctness

The strongest result is artifact completeness. Every scenario passed evidence and trace validation. This is necessary for reproducibility, but it is not sufficient for correctness. A

TABLE V
CONTROLLED WORKFLOW EVALUATION ON 12 REAL NVD CVES (CURATED BENCHMARK, NOT AN INDEPENDENT EFFICACY SAMPLE)

CVE ID	Input Type	Input	Context Type	Context	Score Δ	Priority Shift (Δ_{cat})
CVE-2026-4251	CVSS-BT	1.1	CVSS-BTE	1.1	0.0	low → low (0)
CVE-2026-4252	CVSS-BT	8.9	CVSS-BTE	8.8	-0.1	high → medium (-1)
CVE-2026-4270	CVSS-B	6.8	CVSS-BE	6.8	0.0	medium → high (+1)
CVE-2026-28490	CVSS-B	8.3	CVSS-BE	8.3	0.0	high → critical (+1)
CVE-2026-28498	CVSS-B	8.2	CVSS-BE	8.1	-0.1	high → high (0)
CVE-2026-29510	CVSS-B	5.1	CVSS-BE	5.1	0.0	medium → low (-1)
CVE-2026-29513	CVSS-B	5.1	CVSS-BE	5.1	0.0	medium → medium (0)
CVE-2026-29520	CVSS-B	5.1	CVSS-BE	5.1	0.0	medium → high (+1)
CVE-2026-29521	CVSS-B	5.1	CVSS-BE	5.1	0.0	medium → high (+1)
CVE-2026-3644	CVSS-B	6.0	CVSS-BE	5.9	-0.1	medium → low (-1)
CVE-2026-4224	CVSS-B	6.0	CVSS-BE	6.0	0.0	medium → high (+1)
CVE-2026-4253	CVSS-BT	2.0	CVSS-BTE	2.0	0.0	low → medium (+1)

completely documented recommendation can still contain an incorrect metric interpretation. Future expert evaluation must therefore assess semantic agreement separately from schema completeness.

This distinction is particularly important for automated workflows. Fluent narrative is not evidence of correctness. The architecture requires structured sources, uncertainty fields, and human authorization checkpoints to reduce the risk that generated explanations are mistaken for authoritative decisions.

B. Relationship to Other Prioritization Signals

The workflow complements rather than replaces exploit prediction and stakeholder decision models. EPSS can contribute time-sensitive threat probability. SSVC can contribute stakeholder-specific decision logic. Asset management can contribute exposure and mission context. CVSS Environmental metrics provide a standardized location for selected consumer-side conditions.

A practical implementation could ingest those signals while preserving their distinct meanings. Combining them into an unlabeled composite number would reduce interpretability. The proposed artifact instead records the evidence source and the role it played in the recommendation.

C. Operational Use

An organization could deploy the workflow between vulnerability ingestion and ticket creation. New CVE data would initialize the Base record. Asset and control evidence would populate the context model. The watcher would prepare a candidate assessment and route it to an analyst. After review, the approved record could inform remediation queues and service-level decisions.

The current prototype does not implement this production integration. Its value is the validated data contract and trace package needed before such an integration can be evaluated safely.

D. Governance and Automation Boundaries

The watcher must not silently overwrite official Base information, convert missing data into confident values, or treat a recommendation as reviewed. Sources should carry retrieval timestamps and provenance. Time-sensitive evidence should expire or be flagged for refresh. Conflicting observations should increase uncertainty rather than be resolved invisibly.

Human authority should also be represented as data. A production version would record reviewer identity or role, timestamp, decision, changes, and rationale. Double-blind research artifacts omit personal identifiers, but the workflow design retains the concept of accountable review.

The governance model strictly isolates active operational assets from unexecuted confirmatory protocols. The confirmatory protocol G10B remains explicitly in a defined but unexecuted state. Correspondingly, held-out confirmatory benchmark datasets C1 (real-world cases) and C2 (adversarial/metamorphic cases) remain sealed and unexecuted under a pre-registered fail-closed gatekeeper (`scripts/g10b_confirmatory_gate.py`) to enforce a strict no-retuning constraint. They will not be inspected or executed without formal gatekeeper release and explicit operational authorization.

Furthermore, independent human expert adjudication has not yet been concluded. The research package includes a pre-registered blinded evaluation protocol (`article/expert_review/`), but claims no completed expert agreement or inter-rater reliability. The empirical results presented in this paper reflect solely the descriptive evaluation of the 30 curated scenarios.

VIII. THREATS TO VALIDITY

A. Construct Validity

Evidence coverage and trace completeness measure the presence of artifacts, not their truth. Operational priority is a prototype category and is not an official CVSS score. The evaluation therefore avoids interpreting the category delta as a measurement of risk reduction.

B. Internal Validity

Scenario logic and context assignment were curated by the project. This introduces construction bias (endogenous validation): because the 30 scenarios (12 real NVD records with CVSS v4.0 data and 18 curated synthetic cases) were designed to exercise schema coverage, field boundaries, and priority transitions, the 100.00% evidence coverage, 100.00% trace completeness, and observed priority transitions reflect designed capability rather than an independent natural distribution. They demonstrate that the workflow schema, ingestion pipeline, and governance gates function as designed across diverse asset profiles, but do not establish independent empirical proof of predictive superiority, operational accuracy, or real-world risk reduction. Independent expert adjudication is required to test whether analysts agree with candidate metrics.

C. External Validity

The dataset contains only 30 scenarios. The NVD sample is time-bounded, and the synthetic cases do not represent an empirical enterprise asset distribution. Results should not be generalized to all organizations, industries, or vulnerability classes.

D. Conclusion Validity

The evaluation is descriptive and does not perform hypothesis testing. It does not compare remediation time, exploit outcomes, analyst workload, or prediction accuracy against a control group. The reported percentages describe the current artifact package only.

IX. Reproducibility

The repository contains the scenario CSV, metrics JSON, trace artifacts, generation scripts, validators, Markdown manuscript, LaTeX manuscript, bibliography, compiled PDF, and a SHA-256 manifest. Generated tables are derived from the dataset rather than copied manually.

Reproduction requires running the validators and the LaTeX build sequence. The compilation report records page count, bibliography status, and warnings. The double-blind manuscript omits author and affiliation information.

The artifact package also retains explicit claim boundaries: NVD records are real vulnerability records, their consumer contexts are curated, the priority delta is custom, all recommendations require human review, and no production validation is claimed.

X. Standardized Adjudication Protocol Specification

To support transparent external verification and future organizational deployment, this paper formalizes an open, standardized adjudication protocol specification and reproducible evaluation package (`article/expert_review/`). Crucially, this protocol is presented as a specification deliverable; no independent human expert adjudication has been concluded in the present study. Specifying this protocol does not constitute completed empirical validation and does not eliminate the construction and endogenous selection bias inherent in the 30 curated scenarios. External execution remains necessary to measure empirical inter-rater agreement and operational generalizability.

A. Blinded Review Design

Each reviewer receives a counterbalanced packet containing the Base vector, Base score, Base severity, consumer deployment context, security requirements, controls, and evidence. CVE identifiers, source URLs, watcher recommendations, priority deltas, and rationales are withheld during the independent review.

Two deterministic packet orders reduce the likelihood that fatigue or learning effects are confounded with a single presentation sequence. Reviewers record Security Requirements, Modified Base metrics, an Environmental vector, operational priority, confidence, evidence sufficiency, missing evidence, ambiguity, and review duration.

B. Agreement Measures

The analysis plan reports raw metric-level agreement in addition to chance-corrected measures. Fleiss' kappa or Krippendorff's alpha can be used for multi-reviewer categorical agreement, depending on missing responses. Ordered priority categories can be analyzed using weighted agreement. Review time, confidence, evidence sufficiency, defer rates, and watcher override rates are reported separately.

The operational priority remains a prototype category and is not an official CVSS score. Agreement with the watcher is not treated as proof that either the watcher or a reviewer is correct.

C. Adjudication

After independent responses are locked, disagreements are reviewed in a structured adjudication stage. The adjudication record distinguishes insufficient evidence, ambiguity, reviewer interpretation differences, data-entry errors, watcher errors, specification interpretation issues, and operational-priority framework issues.

This standardized protocol specification strengthens the human-in-the-loop design by defining formal procedures to measure where automation assists analysts and where it requires correction. No expert agreement results or human adjudication data are claimed in the present study.

XI. Operational Adoption Path

A staged adoption process can reduce risk. In the first stage, the watcher runs in observation mode and produces recommendations that do not affect remediation queues. Analysts compare the evidence package with their normal assessment. In the second stage, accepted recommendations may prepopulate tickets while analysts remain responsible for approval. In the third stage, organizations can measure review time, disagreement rates, stale-evidence frequency, and decision consistency.

Expert evaluation should use multiple reviewers and a blinded scenario set. Agreement can be measured per Environmental metric and per final operational category. Review effort should be recorded independently of agreement so that automation does not appear beneficial merely because it encourages rapid acceptance.

A production study should also monitor reversals. When new threat or asset evidence arrives, the workflow should generate a new trace version rather than overwrite the previous assessment. This would allow researchers to examine whether recommendations change for defensible reasons and whether uncertainty flags predict later revisions.

XII. Conclusion

This paper presents an evidence normalization, governance, and traceability workflow for operationalizing CVSS v4.0 Environmental metric assessment. The method separates official Base information from curated consumer context, records evidence and uncertainty, resolves candidate values under explicit governance policies, requires human authorization, and exports reproducible trace artifacts.

The contribution separates specification-level validation (achieving 486,472/486,472 FIRST reference corpus conformance and zero violations across 10,000 metamorphic

executions) from controlled workflow evaluation. Across 30 curated hybrid scenarios, the workflow achieved complete evidence and trace coverage and produced operational priority changes in 22 cases under controlled conditions subject to construction bias, while retaining a non-autonomous workflow in which official scoring decisions remain subject to explicit human authorization; independent expert adjudication was not part of this evaluation. Confirmatory protocol G10B remains defined and unexecuted, with datasets C1 and C2 sealed.

Future work will execute independent expert adjudication under the pre-registered blinded protocol, measure inter-rater agreement and review effort, integrate production-like asset and control sources, and compare decisions with complementary approaches such as EPSS and SSVC.

REFERENCES

[1] FIRST, "Common Vulnerability Scoring System Version 4.0," https://www.first.org/cvss/v4.0/, accessed: 2026-07-13.

[2] ——, "CVSS v4.0 Specification Document," https://www.first.org/cvss/v4.0/specification-document, accessed: 2026-07-13.

[3] ——, "CVSS v4.0 User Guide," https://www.first.org/cvss/v4.0/user-guide, accessed: 2026-07-13.

[4] ——, "CVSS v4.0 Implementation Guide," https://www.first.org/cvss/v4.0/implementation-guide, accessed: 2026-07-13.

[5] C. Frühwirth and T. Männistö, "Improving CVSS-based vulnerability prioritization and response with context information," in *2009 3rd International Symposium on Empirical Software Engineering and Measurement*, 2009, pp. 535–544.

[6] B. Jung, Y. Li, and T. Bechor, "CAVP: A context-aware vulnerability prioritization model," *Computers & Security*, vol. 116, p. 102639, 2022.

[7] H. Howland, "CVSS: Ubiquitous and broken," *Digital Threats: Research and Practice*, vol. 4, no. 1, pp. 1–12, 2023.

[8] J. Spring, A. D. Householder, E. Hatleback, A. Manion, M. Oliver, V. S. Sarvepalli, L. Tyzenhaus, and C. G. Yarbrough, "Prioritizing vulnerability response: A stakeholder-specific vulnerability categorization, version 2.0," Carnegie Mellon University Software Engineering Institute, Tech. Rep., April 2021. [Online]. Available: https://www.sei.cmu.edu/documents/606/2021_019_001_653461.pdf

[9] J. Jacobs, S. Romanosky, I. Adjerid, and W. Baker, "Improving vulnerability remediation through better exploit prediction," *Journal of Cybersecurity*, vol. 6, no. 1, p. tyaa015, 2020.

[10] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, "Exploit prediction scoring system," *Digital Threats: Research and Practice*, vol. 2, no. 3, pp. 1–17, 2021.

[11] J. Jacobs, S. Romanosky, O. Suciu, B. Edwards, and A. Sarabi, "Enhancing vulnerability prioritization: Data-driven exploit predictions with community-driven insights," in *2023 IEEE European Symposium on Security and Privacy Workshops*, 2023, pp. 194–206.

[12] M. Souppaya and K. Scarfone, "Guide to enterprise patch management planning: Preventive maintenance for technology," National Institute of Standards and Technology, Tech. Rep. NIST SP 800-40 Rev. 4, 2022.

[13] V. Koscinski, M. Nelson, A. Okutan, R. Falso, and M. Mirakhorli, "Conflicting scores, confusing signals: An empirical study of vulnerability scoring systems," in *Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security*, 2025, pp. 1904–1918.

[14] National Vulnerability Database, "CVE-2026-4251 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-4251, 2026, accessed: 2026-07-13.

[15] ——, "CVE-2026-4252 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-4252, 2026, accessed: 2026-07-13.

[16] ——, "CVE-2026-4270 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-4270, 2026, accessed: 2026-07-13.

[17] ——, "CVE-2026-28490 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-28490, 2026, accessed: 2026-07-13.

[18] ——, "CVE-2026-28498 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-28498, 2026, accessed: 2026-07-13.

[19] ——, "CVE-2026-29510 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-29510, 2026, accessed: 2026-07-13.

[20] ——, "CVE-2026-29513 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-29513, 2026, accessed: 2026-07-13.

[21] ——, "CVE-2026-29520 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-29520, 2026, accessed: 2026-07-13.

[22] ——, "CVE-2026-29521 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-29521, 2026, accessed: 2026-07-13.

[23] ——, "CVE-2026-3644 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-3644, 2026, accessed: 2026-07-13.

[24] ——, "CVE-2026-4224 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-4224, 2026, accessed: 2026-07-13.

[25] ——, "CVE-2026-4253 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-4253, 2026, accessed: 2026-07-13.